



Puertos, servicios y protocolos relevantes

Temas de esta sección:

- Diferencia entre puerto, servicio y protocolo
- Por qué el puerto no define el riesgo por sí solo
- TCP vs UDP en el contexto SOC
- Puertos clave: HTTP/S, DNS, SMB, RDP, SSH, LDAP, WinRM
- Uso legítimo vs uso sospechoso de cada protocolo
- Puertos no estándar y servicios expuestos
- Ejemplos comparativos con análisis integrado



Aunque se usan juntos, no significan lo mismo:

PUERTO	Número que identifica hacia qué servicio intenta comunicarse un sistema.	<i>Ej: 443, 445, 3389, 53</i>
PROTOCOLO	Conjunto de reglas que define cómo se comunican dos sistemas.	<i>Ej: TCP, UDP, HTTP, HTTPS, SMB, RDP</i>
SERVICIO	La funcionalidad que está escuchando o respondiendo en ese puerto.	<i>Ej: Servidor web, servicio de archivos, escritorio remoto</i>

Un puerto common puede ser abusado. Un puerto no estándar puede ser legítimo. El contexto decide.

3.4 | Puertos comunes que aparecen en investigaciones SOC



No es necesario memorizar todos. Lo importante es reconocer los relevantes y saber qué preguntas hacer:

Puerto	Protocolo	Descripción						
20/21	FTP	Transferencia de archivos	80	HTTP	Web sin cifrado	443	HTTPS	Web cifrada
22	SSH	Admin remota Linux	110/143	POP3/IMAP	Correo cliente	445	SMB	Archivos compartidos Windows
23	Telnet	Admin sin cifrado (inseguro)	135	RPC	Comunicación remota Windows	1433/3306	MSSQL/MySQL	Bases de datos
25/587	SMTP	Correo electrónico	139	NetBIOS	Red Windows legacy	3389	RDP	Escritorio remoto Windows
53	DNS	Resolución de nombres	389/636	LDAP/LDAPS	Directorio activo	5985/5986	WinRM	Admin remota PowerShell

3.4 | SMB, RDP y WinRM: uso legítimo vs sospechoso



SMB — Puerto 445	✓ Uso legítimo: Acceso a carpetas compartidas · Servidores de archivos · Backups · Administración IT	✗ Señal de riesgo: Movimiento lateral · Enumeración de shares · Acceso a múltiples hosts en poco tiempo · Propagación de ransomware	Ejemplo de alerta: RRHH-LAP-044 conecta a 42 hosts internos por SMB en 6 min con múltiples intentos fallidos.
RDP — Puerto 3389	✓ Uso legítimo: Administración de servidores · Soporte técnico · Jump servers · Operaciones controladas	✗ Señal de riesgo: Expuesto a internet sin MFA · Desde IPs desconocidas · Fuera de horario · Cuentas privilegiadas desde equipos inusuales	Ejemplo de alerta: RDP expuesto a internet: 450 intentos fallidos en 2 horas, sin MFA habilitado.
WinRM — 5985/5986	✓ Uso legítimo: Administración remota · Scripts IT · Herramientas de gestión · Configuración masiva	✗ Señal de riesgo: Ejecución remota de comandos post-explotación · Movimiento lateral · Abuso de cuentas comprometidas	Ejemplo de alerta: admin.backup desde USER-LAP-091 ejecuta comandos en 12 servidores a las 2 AM sin ticket.